

CACADEMY

FORMAÇÃO AVANÇADA
EM CIBERSEGURANÇA

www.cncs.gov.pt

Ciclo de Negócio em Cibersegurança

Nível F

35 horas

Ciclo de negócio em cibersegurança

Módulo 1, Sessão #1 e #2

0 Plano de estudos

1. Estado da arte *Cyber*
2. NIS2 com foco na Governance Gestão
3. A evolução do CISO e o Modelo Estratégico (McFarlan)
4. *Governance* vs. Gestão
5. Introdução aos Sistemas de Gestão de Cibersegurança
6. Análise de caso

Boas vindas e Introdução

Plano de estudos

9 sessões, totalizando 35 horas de curso, com cinco módulos principais

1.	2.	3.	4.	5.
Estado da Arte e modelo estratégico CISO	<i>Framework</i> SbD e mapa de dependências	Risco de <i>3rd Party</i> e <i>Vendor Management</i>	Gestão <i>3rd Party</i> e a visão colaborativa	Desafios na Era da IA
O tema da confiança na NIS2	Sec. by Design (SbD)	Boas práticas TPRM	ISO 27001 e ISO 27036	IA riscos e ameaças
Modelo de decisão do CISO	<i>Frameworks</i> de trabalho	Política, controlos e <i>Cloud</i>	Requisitos de gestão; controlos	IA GRC e 3rd Party
Caso InterMed 1	Caso InterMed 2	Caso InterMed 3	Caso InterMed 4	Caso InterMed 5
Quiz	Exemplos	Artefactos	Casos	

Plano de estudos

Avaliação contínua: o caso INTERMED

Ciclo de negócio em cibersegurança

Casos práticos (InterMed)



CACADEMY |

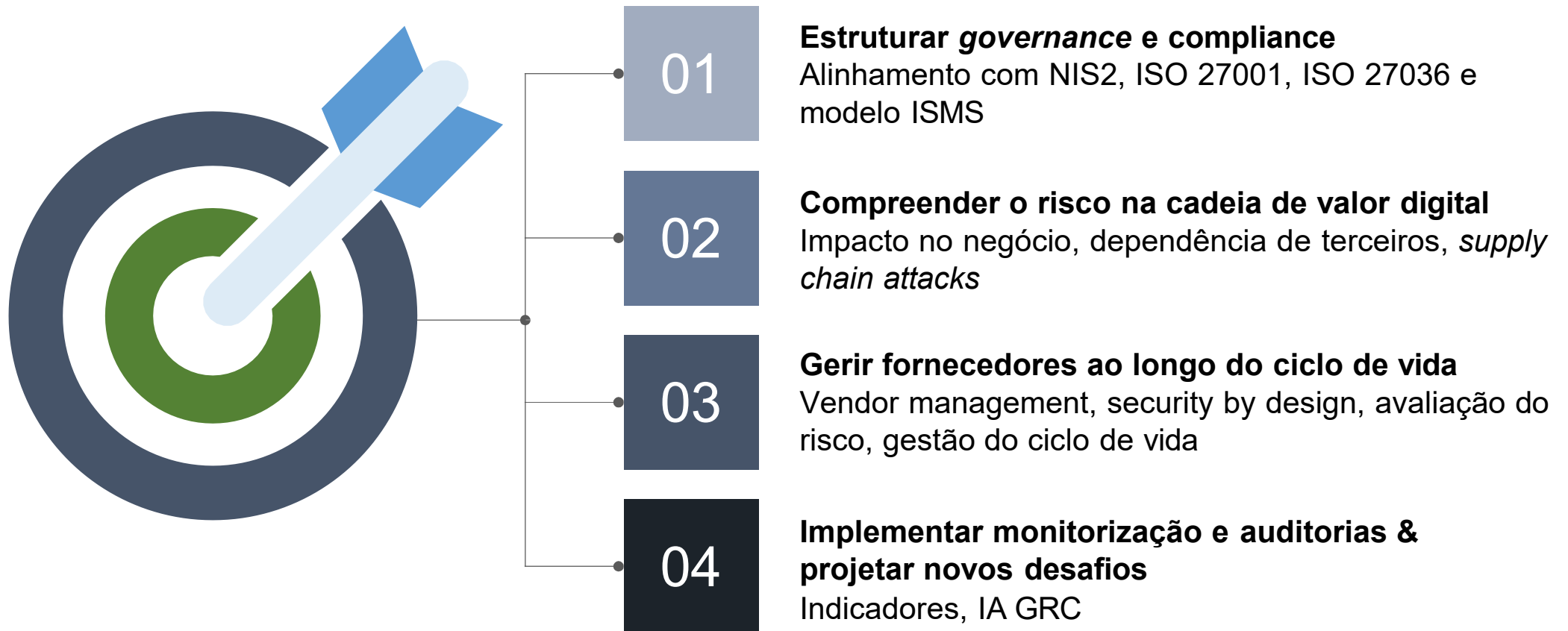
Autor: **Bruno Marques**



Plano de sessões

Módulo	Sessão
Estado da arte e Fundamentos	S1: Estado da Arte e a evolução do CISO (Modelo estratégico).
	S2: NIS2 e o Sistema de gestão para o CISO (introdução)
<i>Frameworks</i> de trabalho e controlos auditoria	S3: Gestão e Segurança por desenho
	S4: <i>Mapping</i> de controlos e impactos na auditoria
Gestão do risco 3rd party e <i>Vendor Management</i>	S5: Risco, <i>Vendor Management</i> & <i>Cloud</i>
	S6: Boas práticas de TPRM (ISO 27001-02, ISO 27036, ENISA)
Gestão de Fornecedores e <i>Lifecycle</i>	S7: ISO 27036 – Sistema de gestão integrado
	S8: <i>Lifecycle</i> de fornecedores (ISO 27036) e visão colaborativa
Desafios e riscos emergentes	S9: Tendências, IA e novos desafios para o CISO

Objetivos



Apresentação

Nuno Salvador

Chefe de Divisão de Sistemas de Informação e Transformação Digital – Município de Pombal

Professor Adjunto Convidado Universidade de Leiria e Oeste (Politécnico de Leiria)

Apresentação



Expetativas iniciais?

Recursos

Ciclo de negócio em cibersegurança

Aulas e partilha

Plano de estudos
Suportes das aulas
Caso de aplicação
Templates

 CACADEMY

Área colaborativa

Debate, temas

Introdução

The road so far...



Elevado ruído na fase de implementação (NIS2/TPRM) – Ausência de um modelo estratégico de apoio ao CISO, com dificuldade em se distinguir *Governance* de Gestão.



Ausência de padronização consistente - Falta de critérios comuns (ex: análise de maturidade / *scoring*), com potencial perda de eficiência e altos custos de conformidade.



Necessidade de visão holística e integrada - integração entre cyber, risco, negócio e *supply chain*, com destaque na gestão integrada de 3rd party.



Complexidade crescente da cadeia de fornecimento digital e riscos emergentes - Dependência de múltiplos fornecedores (3rd / 4th parties), incluindo IA – LLM 3rd party.

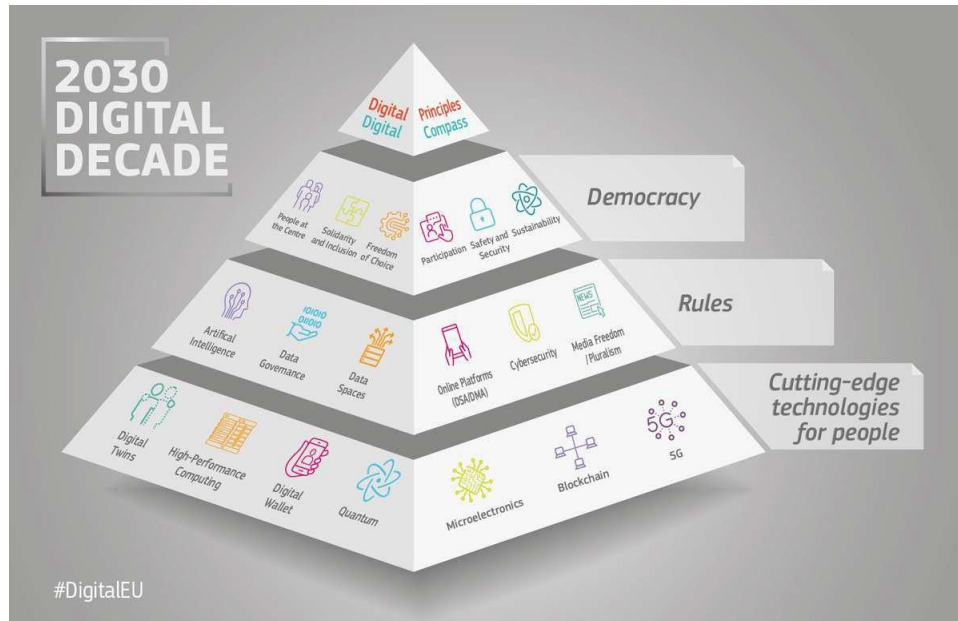
Agenda

Módulo 1 (S1, S2)

- Introdução e as interdependências num mundo conectado
- Requisitos *Governance*, risco e gestão de terceiros (NIS2)
- Panorama geral da Cibersegurança (*drivers* de complexidade)
- A (nova) perspetiva do CISO
 - i) A evolução estratégica do CISO
 - ii) Modelo de decisão estratégica (MacFarlan)
 - iii) Instrumentos do CISO – Introdução
- Análise de caso: Mapeamento da cadeia de valor & MacFarlan
- Conclusão

Introdução ao mundo de interdependências Desafios estratégicos da Cibersegurança (e do CISO)

Introdução



A Estratégia Digital Europeia e a Década Digital 2030

A visão europeia para 2030 assenta numa **transformação digital profunda e sustentável**

A Cibersegurança emerge, neste quadro, como um dos *enablers* mais decisivos.

Cibersegurança: sem ela, nenhum destes pilares poderá sustentar-se de forma duradoura

Introdução

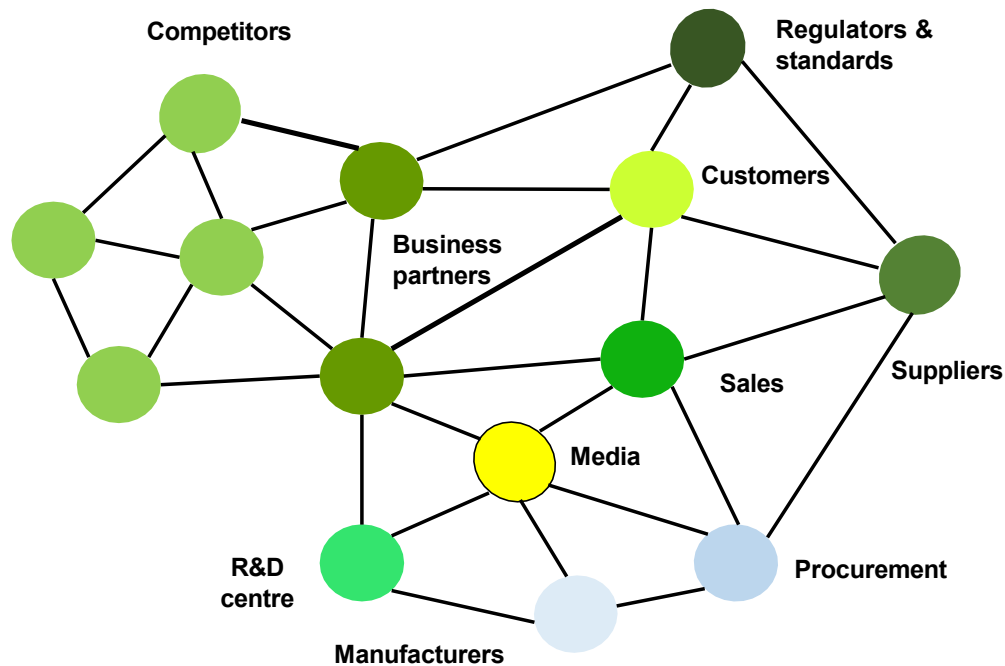
Cibersegurança como **Condição de Possibilidade** da Europa Digital



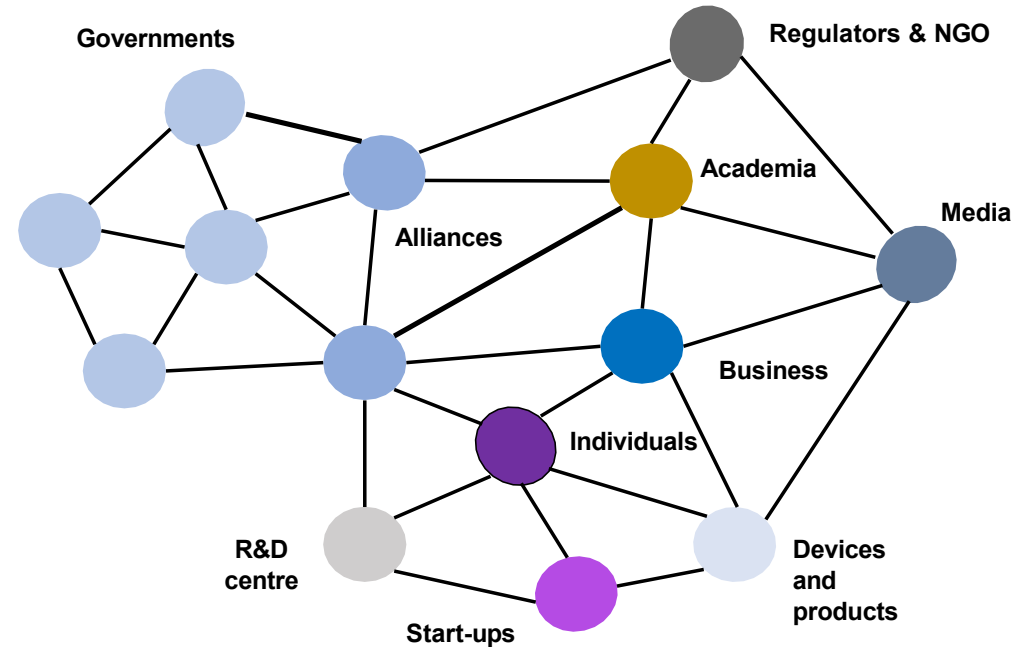
A cibersegurança não é apenas um *enabler* técnico dos 5 Pilares digitais — **é um imperativo de soberania, de coesão social e de competitividade global.**

Qual é o ambiente competitivo global?

A visão dos ecossistemas e das redes colaborativas



BUSINESS ENVIRONMENT



CYBER ENVIRONMENT

Um mundo interconectado: mais valor, mais dependência, mais exposição

Os negócios operam hoje em ecossistemas digitais interdependentes — clientes, fornecedores, plataformas cloud, dados e cadeias de abastecimento ligados em tempo real.

O risco *cyber* deixou de ser um problema isolado de TI e tornou-se uma **variável estrutural de continuidade, confiança e execução do negócio.**



Interdependência crescente

Supply chains opacas, dependência tecnológica e adoção acelerada de IA amplificam a superfície de falha.

Propagação de impacto

Uma falha num ponto do ecossistema propaga impacto operacional, reputacional e regulatório por toda a cadeia de valor.

Risco além da empresa

O risco relevante já não está só "dentro da empresa" — está nas dependências que sustentam o modelo de negócio.

Como sabemos que é real?

A queda em dominó: os *stakeholders* antes e depois de nós...



Confiança: De Valor Reputacional a Imperativo Estratégico



Resiliência estratégica

Num ambiente interconectado, resiliência deixou de ser um tema técnico e tornou-se **condição para operar, crescer e manter confiança.**

Pilar da economia

A confiança deixou de ser um fator reputacional para se tornar um **elemento central da estratégia de cibersegurança.**

O Problema: Segurança Desalinhada com o Negócio

Durante décadas, a cibersegurança foi tratada como uma **função técnica de suporte** — reativa, isolada e difícil de justificar ao board.

Segurança = IT

Percepção histórica de que segurança é um problema técnico, sem ligação à estratégia ou à criação de valor.

Investimento Reativo

Orçamentos aprovados após incidentes, sem critério estratégico. Ciclo de resposta em vez de prevenção orientada por risco.

Sem Ligação ao Negócio

Incapacidade de traduzir riscos técnicos em impacto financeiro ou operacional compreensível para executivos e board.

Over-investment

Recursos alocados em áreas pouco críticas para o negócio, gerando desperdício de CAPEX/OPEX.

Under-protection

Ativos e processos verdadeiramente estratégicos ficam expostos por falta de priorização adequada.

Justificação ao Board

Sem linguagem de impacto de negócio, o CISO perde credibilidade e capacidade de influência executiva.

Solução #1: Modelo de decisão estratégica

É necessário um alinhamento entre gestão da cibersegurança e o negócio

O que muda na percepção?

Cyber **não** é um custo de conformidade nem uma função técnica isolada.

É uma capacidade estratégica que protege o modelo de negócio e viabiliza a transformação com confiança.

O que o CISO entrega?

- ✗ **A Conformidade não é o destino da Cibersegurança**
- ☐ A Segurança é uma capacidade estratégica
- ✗ **Não é segurança informática mas segurança de informação**
- ☐ O investimento deve ser proporcional ao Risco
- ☐ O objetivo final é a Resiliência Estratégica

Solução #2: Cibersegurança como Função Estratégica

O que era antes?

A cibersegurança era encarada como uma **função técnica de IT** — reativa, operacional e desligada dos objetivos de negócio.

Era um custo, não um investimento.

- Departamento de suporte técnico
- Resposta a incidentes isolados
- Sem voz na tomada de decisão

O que (deverá ser) é agora?

- ✓ A cibersegurança tornou-se uma **função estratégica de continuidade e confiança**.
- ✓ É um pilar da Confiança da Organização
- ✓ Protege a reputação, garante a operação e habilita o crescimento do negócio.

"Security = Business Enabler" — A segurança não protege apenas sistemas; protege a capacidade da organização de operar, crescer e ser confiável.

A nossa missão: Um novo modelo para o CISO

A *cyber* deve ser vista não como travão, mas como ***enabler*** de crescimento seguro, confiança no mercado e decisão estratégica.



IA & Inovação

Adoção acelerada de IA aumenta velocidade, mas introduz novas vulnerabilidades e exigências de controlo.



Terceiros & Ecossistemas

Dependência de parceiros amplia risco de concentração, opacidade e propagação de incidentes.



Regulação & Stakeholders

Requisitos legais e contratuais colocam a governação *cyber* no centro da agenda executiva.



Secure by Design

Segurança integrada desde o início reduz vulnerabilidades, melhora fiabilidade e aumenta confiança no negócio.

Iremos abordar estes 4 temas durante o nosso curso de “Ciclo de Negócio em Cibersegurança”

Qual é o principal risco de um CISO atuar apenas como função técnica?

- a) Necessidade de contratação de serviços
- b) Aumento de custos IT
- c) Desalinhamento com prioridades de negócio
- d) Redução de compliance

Quiz

Os atuais desafios regulamentares (resumo)

Resumo: o que sabemos até agora?



NIS2: ponto de situação

1

QUEM

Entidades essenciais, importantes,
Org Públicas tipo **A** ou tipo **B**

2

QUANDO

3 de Abril (DL 125/2025 entra em vigor)
22 de Abril (Portal de registo das entidades)
+ 60 dias e depois **24 meses** de “transição”

3

ONDE

Organização – iniciar pelos ativos mais críticos
(análise do risco)
3rd party – foco nos fornecedores de maior risco

4

PORQUÊ

Estratégia Digital EU
Estabilidade das sociedades (- risco sistémico)
Resiliência das Organizações & Conformidade

5

O QUÊ

NIS2: Diretiva EU
RJCibersegurança: Quadro de execução em PT
Outros regul. / requisitos setoriais: *crosswalk*

6

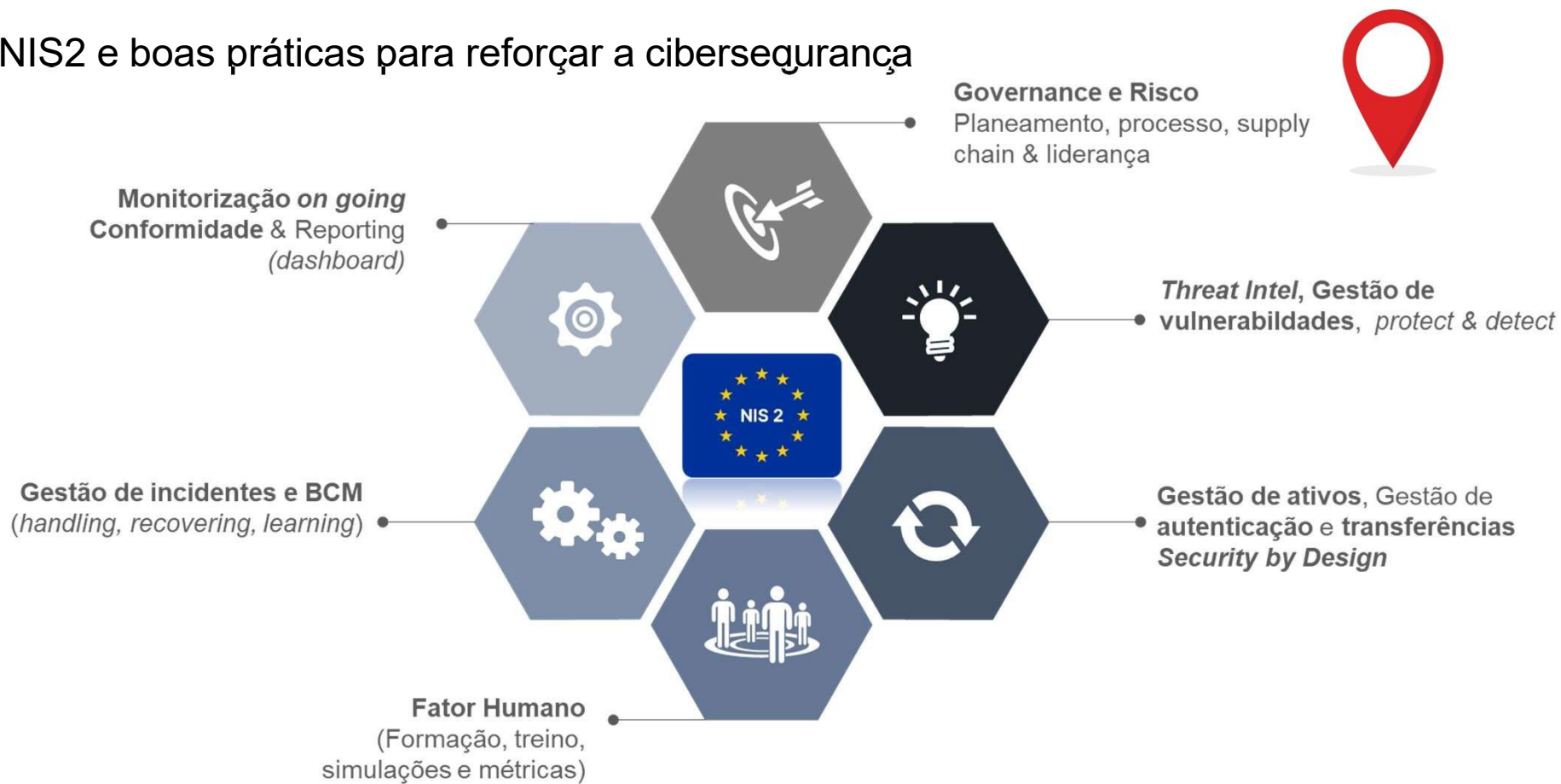
COMO

QNRCS: instrumento de operacionalização
ENISA tech guide: guia de implementação
ISO 27k, CIS, etc.: Referenciais e Boas Práticas

Os pilares da NIS2



NIS2 e boas práticas para reforçar a cibersegurança



Fonte: CIIWA

Temas em destaque (exemplo)



O Artigo 21 exige que as **medidas de cibersegurança sejam apropriadas** para os riscos;
Ao avaliar os riscos, o NIS2 exige que as empresas levem em consideração o seguinte:

- exposição aos riscos
- tamanho da empresa
- probabilidade de ocorrência de incidentes e sua gravidade
- impactos sociais e económicos dos incidentes

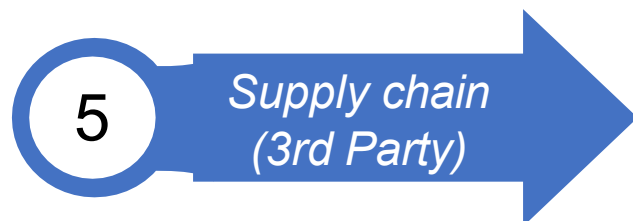


O Artigo 21 exige que as empresas “**tomem medidas técnicas, operacionais e organizacionais apropriadas e proporcionais** para gerir os riscos de segurança da rede e dos sistemas de informação... e para prevenir ou minimizar o impacto de incidentes **nos destinatários dos seus serviços e em outros serviços.**”

Além disso, o Artigo 21 exige uma abordagem de todos os riscos, o que significa que as empresas precisam se preparar para uma **ampla gama de ameaças potenciais.**

Uma das medidas consiste na Segurança por Desenho

Temas em destaque (exemplo)



O Artigo 21 exige um foco nos riscos relacionados a **fornecedores diretos e prestadores de serviços**, em particular:

- **Vulnerabilidades** específicas de cada fornecedor direto e prestador de serviços
- A **qualidade geral** dos produtos e práticas de **cibersegurança** de fornecedores e prestadores de serviços
- Procedimentos de **desenvolvimento seguro** de fornecedores e prestadores de serviços

Segundo a NIS2, qual é o papel do órgão de gestão?

- a) Delegar totalmente a segurança no CISO
- b) Aprovar apenas orçamento e as políticas, sendo informado de todas as atividades
- c) Supervisionar e ser responsável pela gestão do risco, incluindo a aprovação do plano de meios
- d) Ignorar temas técnicos

Quiz

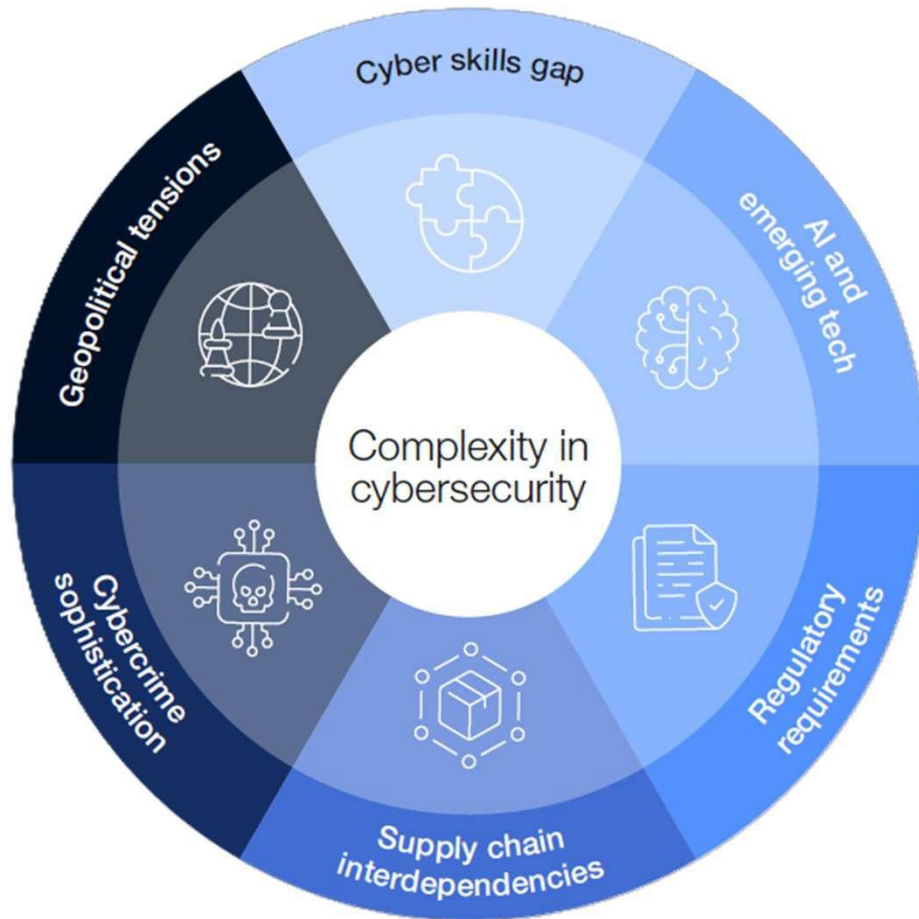
Segundo a NIS2, qual o maior risco para o órgão de gestão?

- a) Necessidade de contratação de serviços externos
- b) Risco financeiro direto
- c) Responsabilidade por falhas de supervisão
- d) Falta de ferramentas

Quiz

Compreender a complexidade

Complexidade na Cibersegurança



Um ciberespaço complexo com incertezas geopolíticas, crescente desigualdade digital e ameaças sofisticadas. sendo imperioso reforçar uma cultura de cibersegurança

Perante um ambiente conflitual é imperioso reforçar a cultura de cibersegurança

Impactos na dinâmica das Organizações

Organizações privadas já não são "danos colaterais" — **são alvos deliberados**



Espionagem industrial

China-nexus (+200–300% em financeiro, media, manufacturing)



Disrupção económica

Ransomware em supply chain amplifica impacto



Pressão geopolítica

Hacktivismo coordenado com narrativas de agentes estatais



Vetor de acesso

Fator humano e fornecedores como meios para aceder a sistemas

Desafios do presente

Tendências-fortes em 2025

Phishing com IA

E-mails indistinguíveis de comunicações legítimas, gerados em milissegundos

Ransomware: Mais Rápido e Cirúrgico

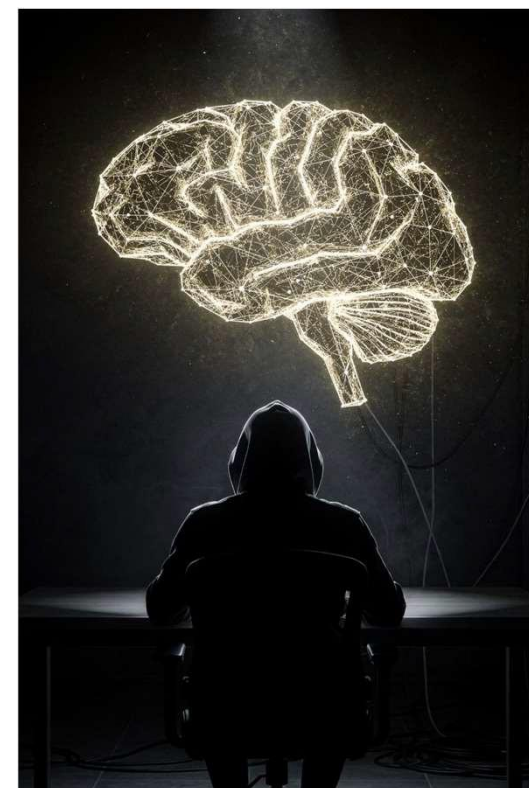
Exfiltração antes da cifragem como padrão: Extorsão tripla: dados, operações e reputação

Superfície de Ataque em Expansão

Ambientes Cloud e Híbridos, IOT, 3rd Party integrados, Dispositivos móveis

Fator humano sob pressão

Engenharia Social como principal ameaça



O Paradoxo da Segurança na era da IA

97%

Experimentação Individual

Profissionais já testaram ferramentas de IA

23%

Políticas Formalizadas

Organizações com governança estruturada

12%

Ambientes Seguros

Empresas com infraestrutura para testes

6%

Preparação Real

Sentem-se verdadeiramente preparados

66%

Barreira Principal

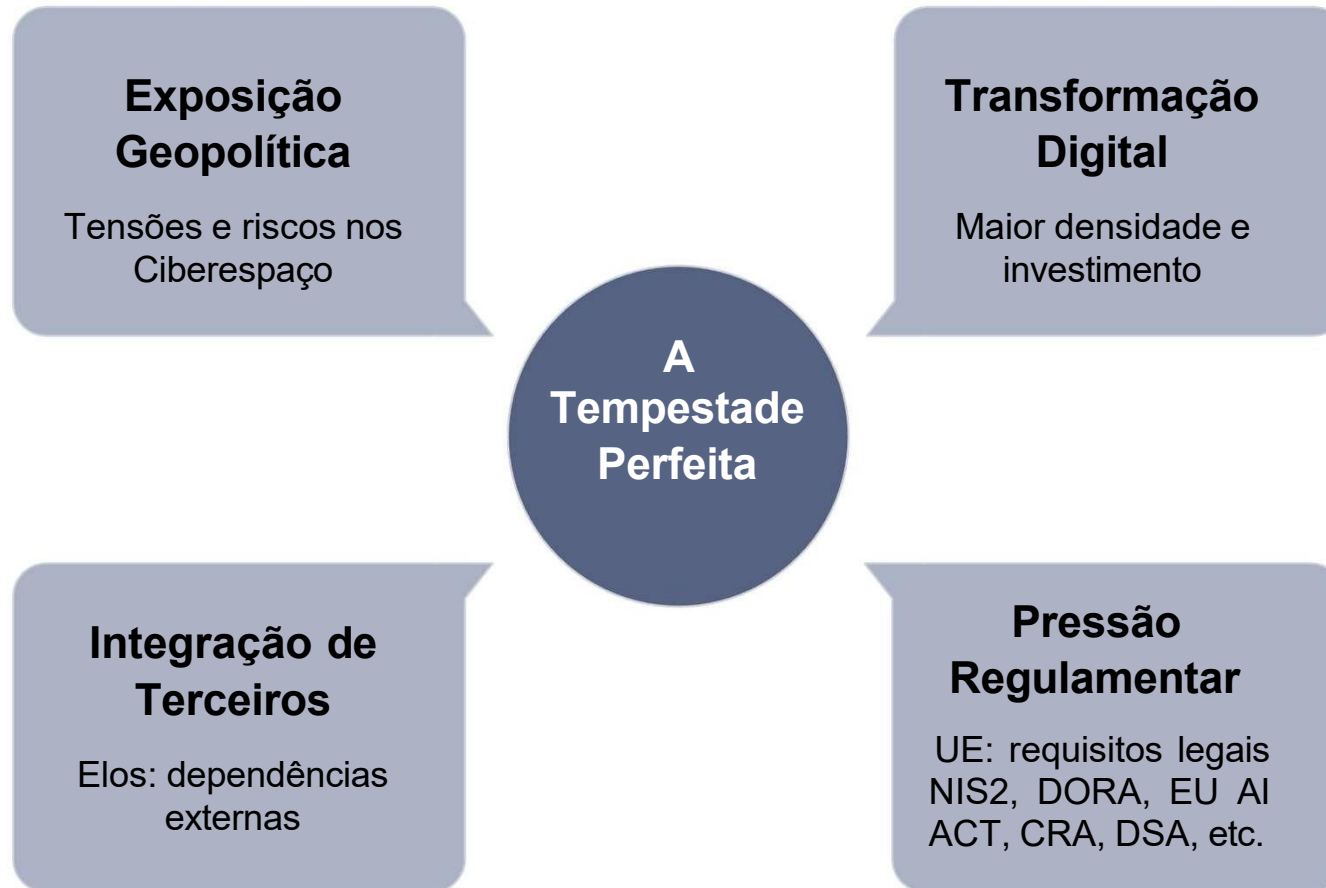
Preocupações com segurança da informação

Riscos Ampliados

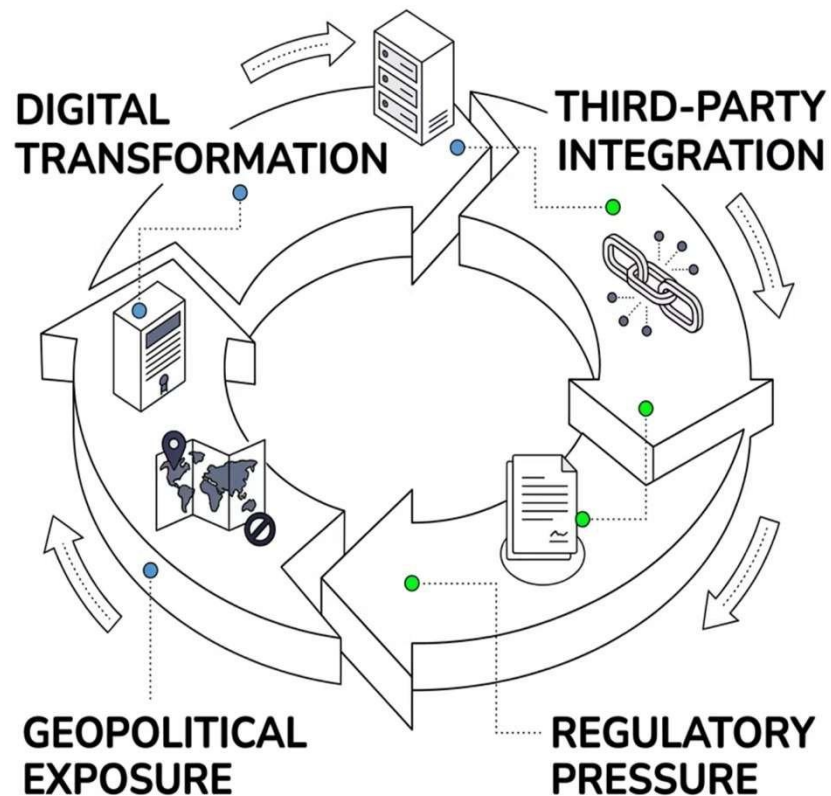
44%

das organizações admitem não dispor de ambientes seguros, expondo dados sensíveis a riscos de confidencialidade e privacidade.

Implicações estratégicas para o CISO: vetores estratégicos



Um Desafio Sistêmico



Digital → Risco de Terceiros & *Sec. by design*

A adoção mais rápida aprofunda dependências no ecossistema e amplia a superfície de ataque

Terceiros → Escrutínio Regulatório

Cadeias de abastecimento complexas atraem atenção regulatória direta e responsabilidade

Geopolítico → Maior risco e sofisticação

As Organizações podem ser danos colaterais ou alvos determinados

Qual é o maior risco na *supply chain* moderna?

- a) Falta de contratos com revisão detalhada
- b) Falta de SLA definidos na fase da operação
- c) Insuficiente Gestão do Risco através de terceiros críticos
- d) Falta de auditorias

Quiz

Plano de estudos

9 sessões, totalizando 35 horas de curso, com cinco módulos principais

1.	2.	3.	4.	5.
Estado da Arte e modelo estratégico CISO	<i>Framework</i> SbD e mapa de dependências	Risco de <i>3rd Party</i> e <i>Vendor Management</i>	Gestão <i>3rd Party</i> e a visão colaborativa	Desafios na Era da IA
O tema da confiança na NIS2	Sec. by Design (SbD)	Boas práticas TPRM	ISO 27001 e ISO 27036	IA riscos e ameaças
Modelo de decisão do CISO	<i>Frameworks</i> de trabalho	Política, controlos e <i>Cloud</i>	Requisitos de gestão; controlos	IA GRC e 3rd Party
Caso InterMed 1	Caso InterMed 2	Caso InterMed 3	Caso InterMed 4	Caso InterMed 5

Quiz

Exemplos

Artefactos

Casos

A evolução do CISO:

- O novo papel do CISO
- O modelo de decisão estratégica: Matriz de MacFarlan

Evolução do CISO



Uma mudança de plano

A mudança não é apenas de competências — é de identidade profissional.

O CISO que permanece no paradigma técnico perde influência nos momentos que mais importam: **quando a organização enfrenta decisões críticas de gestão.**

Evolução do CISO

Da Postura Reativa à Gestão Estratégica

O CISO moderno deixou de ser apenas um responsável técnico para se tornar um **gestor de risco estratégico**, com assento na mesa executiva e responsabilidade direta pela resiliência organizacional.

- Alinhamento da segurança com os objetivos de negócio
- Comunicação do risco em linguagem executiva
- Governance integrada com a liderança de topo

Investimentos Baseados no Risco

Priorização de controlos com base no impacto real no negócio

Foco na Resiliência

Capacidade de recuperar rapidamente, não apenas de prevenir

Papel no ciclo de negócio

Deixou de ser uma função técnica para se tornar um pilar estratégico do negócio moderno, da cadeia de valor à governação do risco.

Desafios do CISO

O negócio moderno é **digital, interdependente e distribuído**. A cadeia de valor já não é linear — é uma rede tecnológica exposta a risco sistémico, dependente de terceiros e vulnerável em cada elo.

📄 ⚠️ A **resiliência estratégica** resultará do **Princípio da Concentração** e do **Custo-Benefício**.

Tecnologias

Dependência de plataformas cloud, SaaS e infraestruturas digitais partilhadas.

Onde estão os pontos críticos para o negócio?

Dependente de Terceiros

Fornecedores, parceiros e subcontratados integram a cadeia crítica de operação.

Quais os que têm impacto na operação e na estratégia?

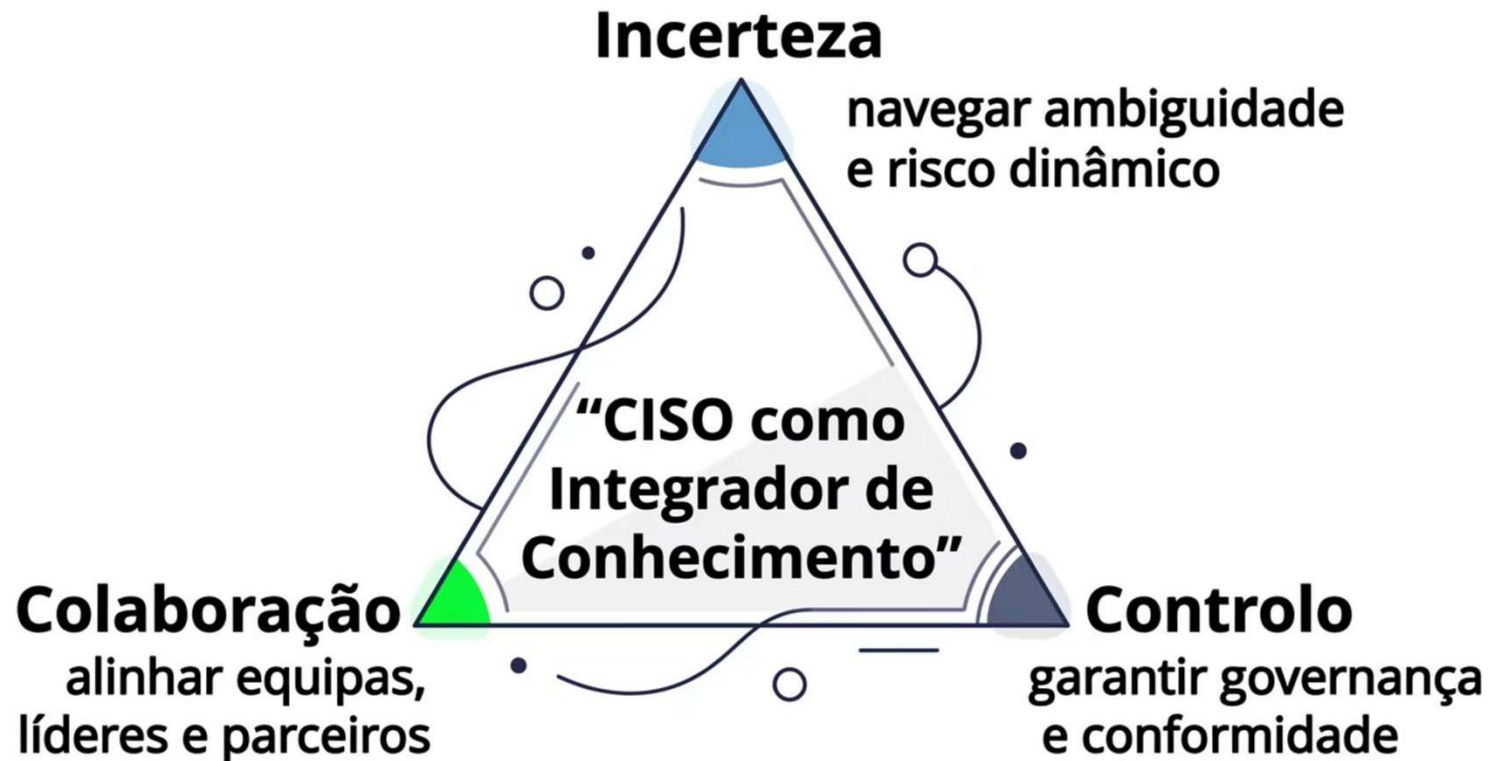
Exposição ao Risco Sistémico

Uma falha num SI pode propagar-se instantaneamente por toda a rede.

Quais os *drivers* de decisão na gestão do risco?

CISO como gestor

Três tensões permanentes definem o novo papel do CISO — e a sua capacidade de as gerir determina a resiliência da organização.



CISO Playbook: conclusões

Tendências principais

Não é um gestor de tecnologia — é um gestor do risco

O papel é fornecer *expertise*, suporte e conselho para que o negócio possa decidir quais os riscos a aceitar, mitigar, transferir ou evitar.

Segurança é uma preocupação de negócio para a sua sustentabilidade

Quando o risco *ciber* se traduz em risco de negócio, os líderes tornam-se mais recetivos a apoiar e financiar iniciativas de segurança.

Conformidade não equivale a segurança

Um CISO eficaz vai além dos requisitos de conformidade e contribui ativamente para a proteção e resiliência real da organização.

A equipa é o maior ativo

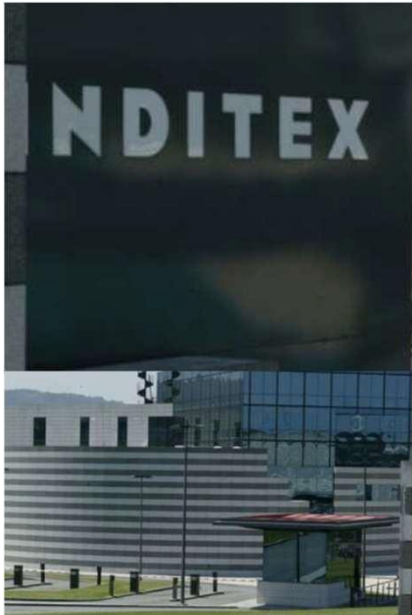
Investir no conhecimento, envolvimento e aprendizagem contínua da equipa é fundamental para o sucesso sustentado de qualquer programa de segurança.

Caso exemplo

Caso exemplo

Inditex sofre um ciberataque com acesso às suas bases de dados

2026



- Em Abril de 2026, a Inditex confirmou um incidente de cibersegurança provocado por uma falha num fornecedor tecnológico externo, garantindo, no entanto, que os sistemas principais e as operações não foram comprometidas.
- Embora com impacto operacional limitado, o caso evidenciou um padrão crescente: **dependência crítica de terceiros e serviços digitais** (cloud, SaaS, parceiros tecnológicos)
- O vetor mais plausível enquadra-se nos padrões atuais: **risco na supply chain / terceiros (3rd party risk)**
- O incidente provocou impactos potenciais:
 - Perturbações em sistemas digitais associados a canais de venda e operação
 - Exposição potencial de dados operacionais e transacionais
 - Risco reputacional em marca global altamente digital

Caso exemplo – Cenário plausível do incidente

2026

Causas potenciais



TRUST



O caso volta a expor os riscos associados à dependência de fornecedores externos, cada vez mais apontados como uma das principais portas de entrada para ciberataques a grandes empresas.



Risks

Impactos mais relevantes

- a) Operacionais
- b) Reputacionais
- c) Legais
- d) Financeiros

Questões

Quais as falhas eventuais neste caso? (TOP 5)

**Política de gestão de acessos em linha com princípio
*need to know basis***

**Dupla validação para alteração de dados pessoais ou
sensíveis (com risco operacional e legal)**

Política de gestão de 3rd Party e lógica de ciclo de vida

Não aplicou políticas de gestão de utilizadores

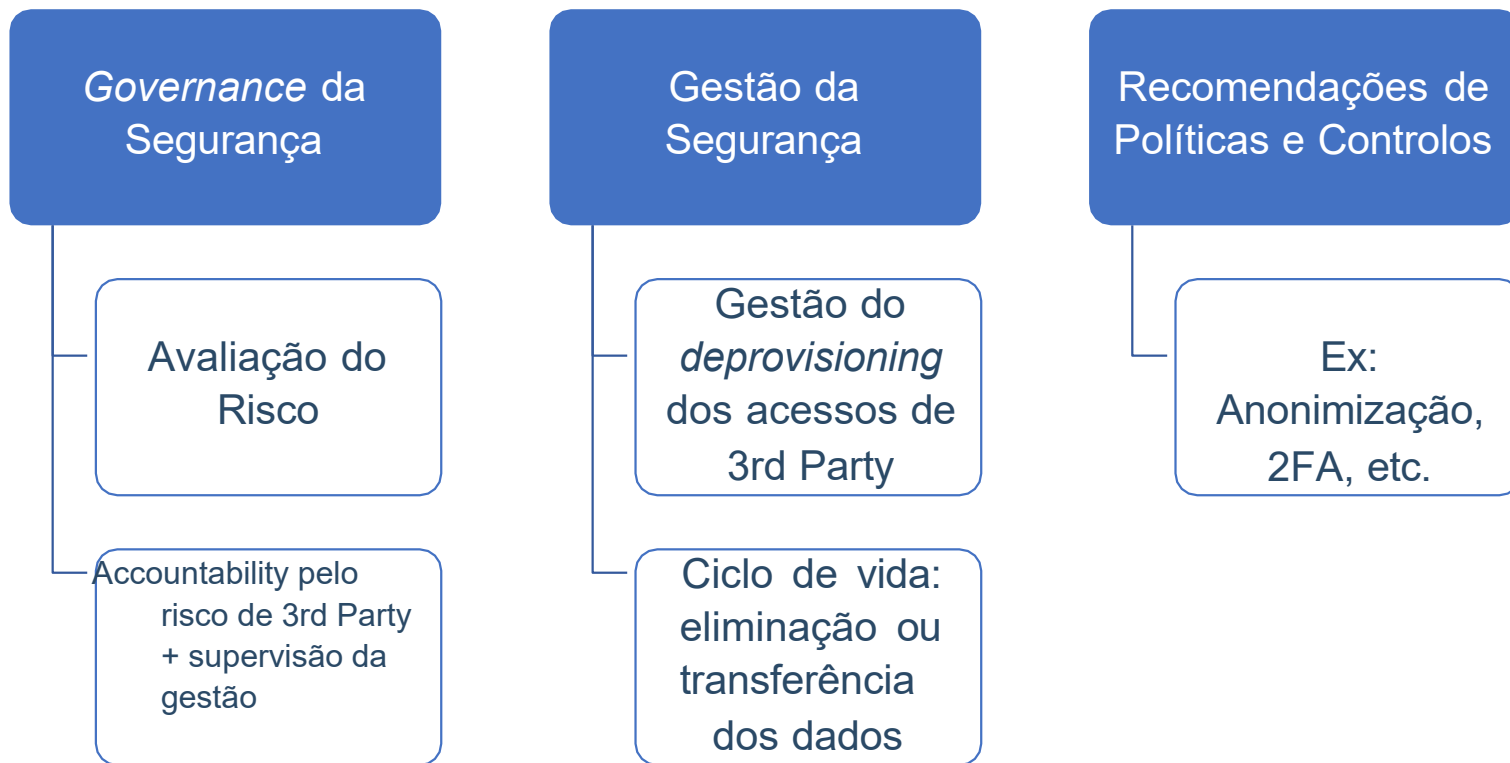
**Logs, monitorização e resposta coordenada a
incidentes.**

Exemplos

1. Falha em Testes de segurança (pen testing)
2. Não aplicou políticas de gestão de utilizadores
3. Utilizador nominativo e password pessoal intransmissível
4. Política de gestão de 3rd Party e lógica de ciclo de vida
5. Política de gestão de acessos em linha com princípio *need to know basis*
6. Dupla validação para alteração de dados pessoais ou sensíveis (com risco operacional e legal)
7. Gestão da rede e acesso (segmentados) aos recursos
8. Logs de auditoria em sistemas que façam tratamento de dados pessoais – pelo menos 90 dias de Logs
9. Gestão do Risco e Plano de tratamento do risco aprovado superiormente
10. Ausência de Resposta a incidentes

Questões

Preencha os tópicos que considera mais importantes neste caso



O Sistema de Gestão de Segurança de Informação

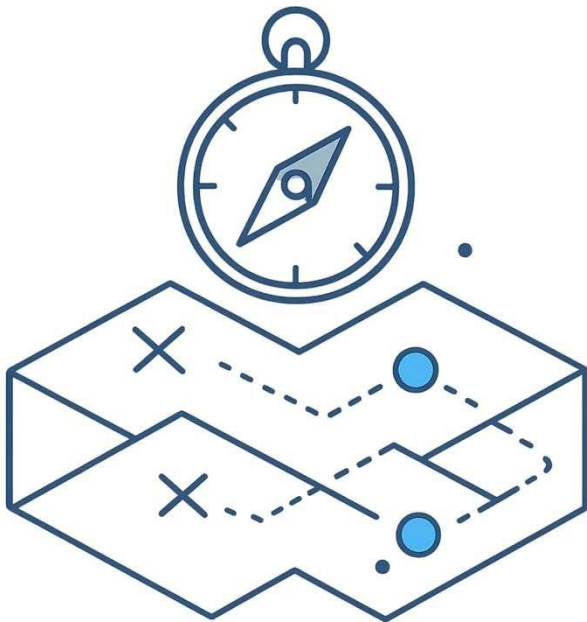
- Governance vs. Gestão
- SGSI
- Papel dos Referenciais

NIST CSF 1.1 vs. 2.0



O Que é *Governance*?

Definição ISACA: A estrutura pela qual as organizações tomam e executam decisões para alcançar os seus objetivos.



A *Governance* não executa — **orienta, supervisiona e responsabiliza.**



O que queremos alcançar?

Definição da direção estratégica e objetivos de cibersegurança

Quais são os riscos?

Identificação e tolerância ao risco ao mais alto nível

Estamos em conformidade?

Supervisão legal, regulatória e responsabilização

Governance vs. Gestão

Exemplos [↗]

GOVERNANCE CYBER

Visão Estratégica

Políticas e Diretrizes

Responsabilidade da Liderança

Supervisão e Conformidade

“O quê” e “Porquê”

GESTÃO CYBER

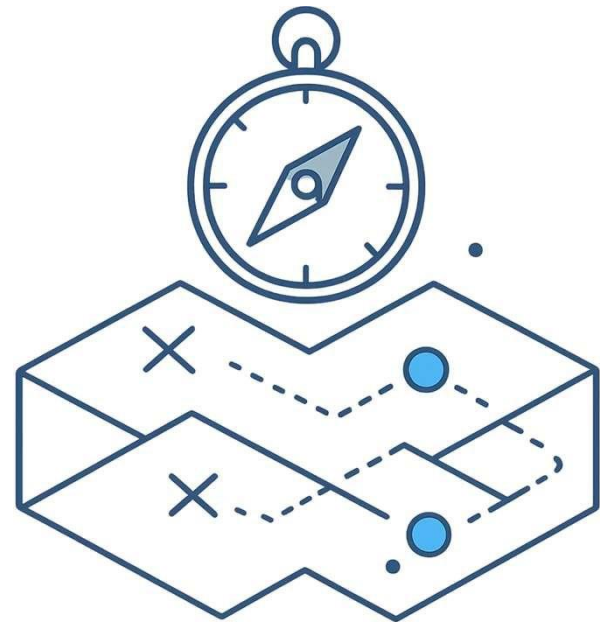
Implementação Técnica

Resposta a Incidentes

Monitorização e Controlos

Gestão de Recursos

“Como” e “Quando”



O modelo estratégico do CISO: vetores estratégicos

O modelo assenta em pilares interdependentes que, em conjunto, permitem ao CISO estruturar decisões de segurança com base em critérios de negócio, risco e valor — e não apenas em critérios técnicos.



Gestão Estratégica (Matriz de MacFarlan)

Realizar o alinhamento entre a Cibersegurança e o negócio



Mapeamento de Dependências Críticas

Identifica onde o negócio depende de tecnologia e terceiros. Traduz falhas sistémicas em impacto financeiro mensurável — a linguagem que o board compreende.



Security by Design

Integra segurança no design de sistemas e serviços **desde o início, proporcional ao risco**. Elimina o custo e a fragilidade do "add-on" tardio em projetos de inovação.



Gestão de Fornecedores

Controla o maior vetor de risco actual: **terceiros e dependências externas**. Classifica fornecedores por criticidade e aplica controlos diferenciados e proporcionais.

Decisão estratégica: a matriz de MacFarlan

O modelo assenta em pilares interdependentes que, em conjunto, permitem ao CISO estruturar decisões de segurança com base em critérios de negócio, risco e valor — e não apenas em critérios técnicos.



Gestão Estratégica (Matriz de MacFarlan)

Realizar o alinhamento entre a Cibersegurança e o negócio



Mapeamento de Dependências Críticas

Identifica onde o negócio depende de tecnologia e terceiros. Traduz falhas sistémicas em impacto financeiro mensurável — a linguagem que o board compreende.



Security by Design

Integra segurança no design de sistemas e serviços desde o início, proporcional ao risco. Elimina o custo e a fragilidade do "add-on" tardio em projetos de inovação.



Gestão de Fornecedores

Controla o maior vetor de risco actual: **terceiros e dependências externas**. Classifica fornecedores por criticidade e aplica controlos diferenciados e proporcionais.

CISO, Estratégia e Ciclo de Negócio

Utilizar a MacFarlan para decisões estratégicas de cyber

O CISO cria valor quando traduz cyber em decisões de negócio sobre continuidade, transformação e vantagem competitiva. A grelha estratégica de McFarlan fornece uma linguagem simples para fazer essa priorização.

Nem tudo tem o mesmo peso

Nem todos os ativos, processos e fornecedores têm o mesmo peso estratégico para o negócio.

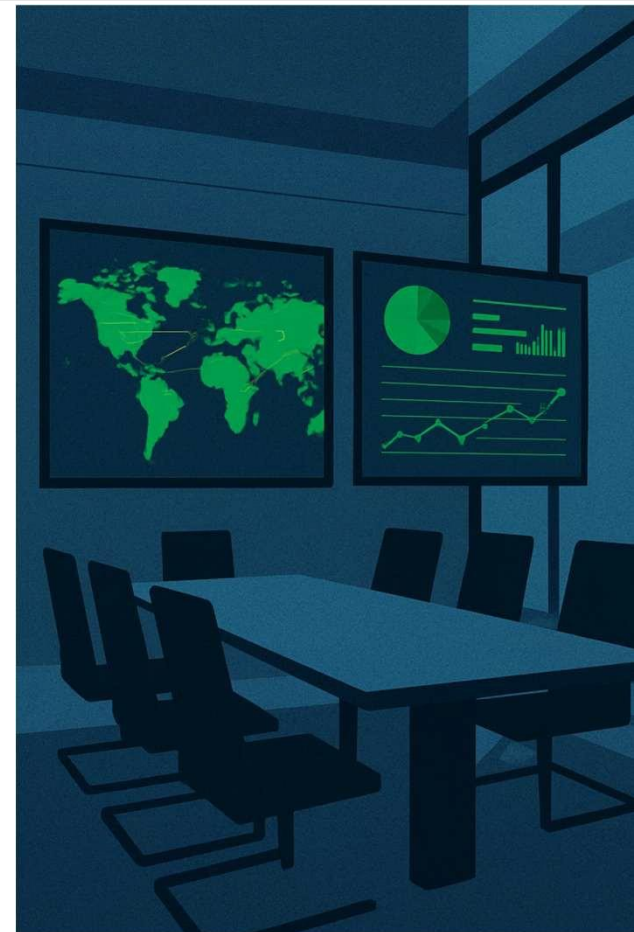
O erro mais comum

Aplicar o mesmo modelo de controlo a tudo é o erro mais frequente e mais custoso.

O que o *board* quer ver

Decisões, prioridades e impacto no negócio — não apenas controlos técnicos.

📌 Cyber não é apenas proteção — é também alocação de atenção executiva.



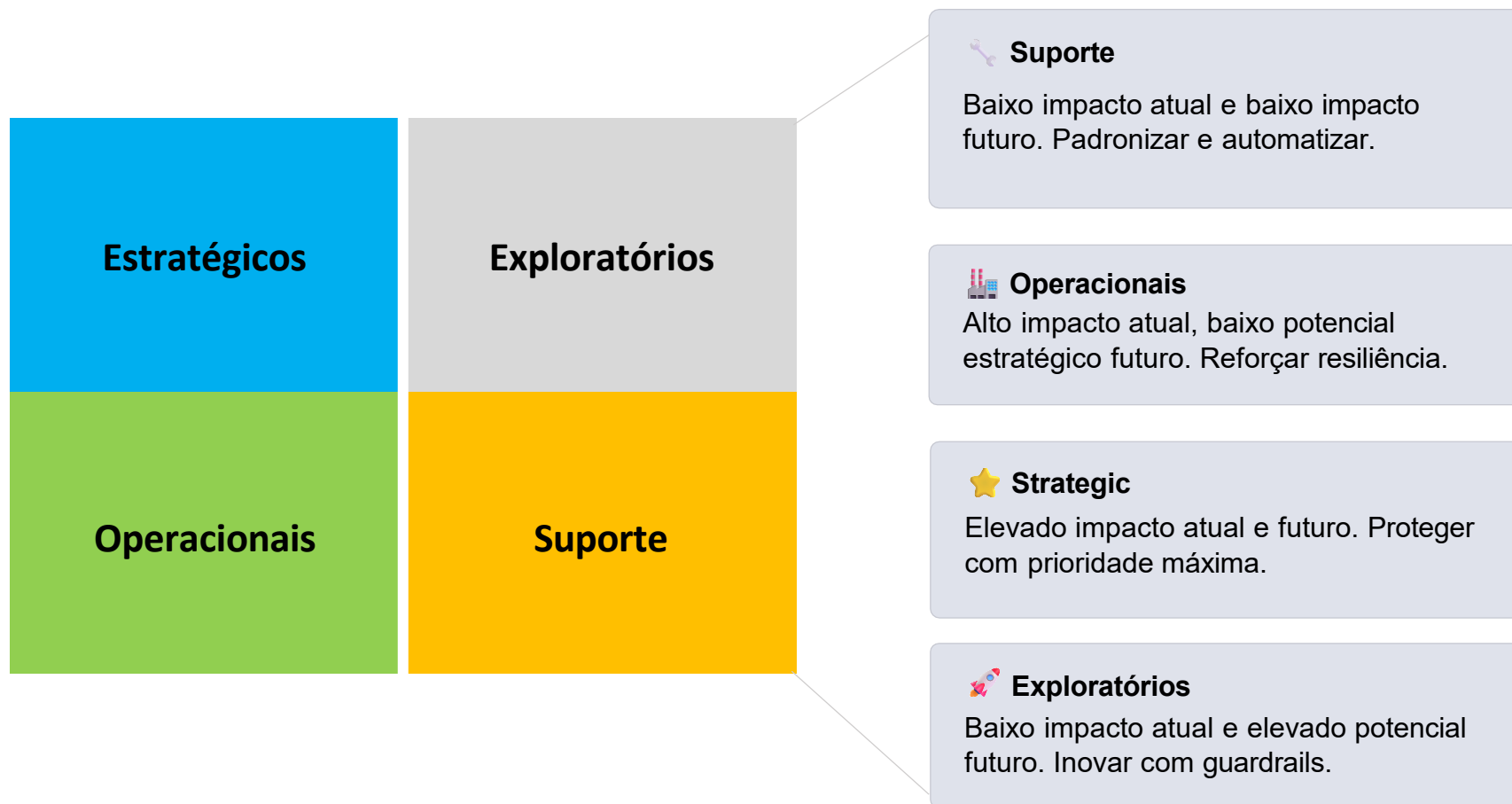
Modelo de decisão estratégica

Gestão Estratégica de SI: Matriz de Portfolio (MacFarlan)



Modelo de decisão estratégica

Gestão Estratégica de SI: Matriz de Portfolio (MacFarlan)



Modelo de decisão estratégica

Como funciona?

Dê exemplos de tipos de SI e posicione-os na Matriz de MacFarlan



#	SI	Portfolio
1	Tickets Lista de espera	
2	Tickets de IT	
3	Loja online	
4	ERP integrado	
5	Point-of-sales	
6	Contabilidade – Administrativo	
7	Agentic AI nos Hipermercado	
8	Self Service	
9	CRM – análise de informação vs. perfil	
10	Footfall – análise comportamental	

1

2

3

4

Modelo de decisão estratégica

Gestão Estratégica de SI: *Racional* para a tomada de decisão



*Outsourcing?
Insourcing?
SLA?*

*Drivers do Risco
vs. Controlos e
Investimento*

*Criticidade dos SI
vs. Requisitos
segurança*

Tradução para a Função CISO

Para o CISO, a grelha responde a quatro decisões fundamentais: o que padronizar, o que tornar resiliente, o que acelerar com guardrails e o que proteger como ativo estratégico do negócio.

Quadrante	Pergunta Executiva	Decisão Típica do CISO
 Support	Vale a pena customizar?	Padronizar e automatizar. Aceitar risco residual controlado.
 Operacional	O negócio pára se falhar?	Reforçar resiliência, redundância e recovery. Testes regulares.
 Exploratório	Pode criar nova vantagem?	Inovar com guardrails. Critérios de go/no-go e risk acceptance formal.
 Strategic	Sustenta confiança e diferenciação?	Proteger com prioridade máxima, patrocínio executivo e supervisão reforçada.

 A conversa muda de "controlo" para "escolha estratégica" — e é aí que o CISO ganha relevância executiva.

Aplicação Prática por Quadrante

O posicionamento em MacFarlan deve ser feito sobre processos, plataformas e terceiros, porque isso altera prioridades de investimento e supervisão. Um mesmo fornecedor pode mudar de quadrante conforme o processo que suporta.



Support

- Payroll e RH
- Colaboração interna
- Intranet corporativa

Padronizar, automatizar, baseline mínimo.



Operacional

- ERP e faturação
- Logística e produção
- Infraestrutura core

Resiliência, recovery e continuidade operacional.



Exploratório

- Piloto de IA generativa
- Novo canal digital
- PoC de analytics avançado

Inovar com guardrails e critérios claros de go/no-go.



Strategic

- E-commerce core
- Dados proprietários
- Ecossistema API e experiência digital do cliente

Proteção máxima, supervisão contínua e patrocínio executivo.

Responsabilidades-Chave e Erros Comuns do CISO

✓ Responsabilidades Fundamentais

- Definir e executar a **estratégia de cibersegurança** alinhada com o negócio.
- Integrar segurança no **ciclo de vida do negócio** e nos processos de aquisição.
- Gerir o **risco de terceiros** e garantir controlos adequados na supply chain.
- Garantir **compliance com NIS2** e demais obrigações regulatórias aplicáveis.
- Promover uma **cultura de segurança** transversal a toda a organização.

✗ Erros que Comprometem o Papel

- **Foco excessivo em tecnologia** — perder de vista o impacto no negócio e na estratégia.
- **Falta de comunicação com o board** — não traduzir o risco técnico para a linguagem da liderança.
- **Segurança desligada do negócio** — atuar como silo em vez de parceiro estratégico.
- **Não compreender a cadeia de valor** — ignorar os riscos que entram pela supply chain.

Qual o principal objetivo do modelo estratégico do CISO?

- a) Reduzir número de ferramentas
- b) Alinhar segurança com impacto no negócio
- c) Criar mais políticas
- d) Centralizar IT

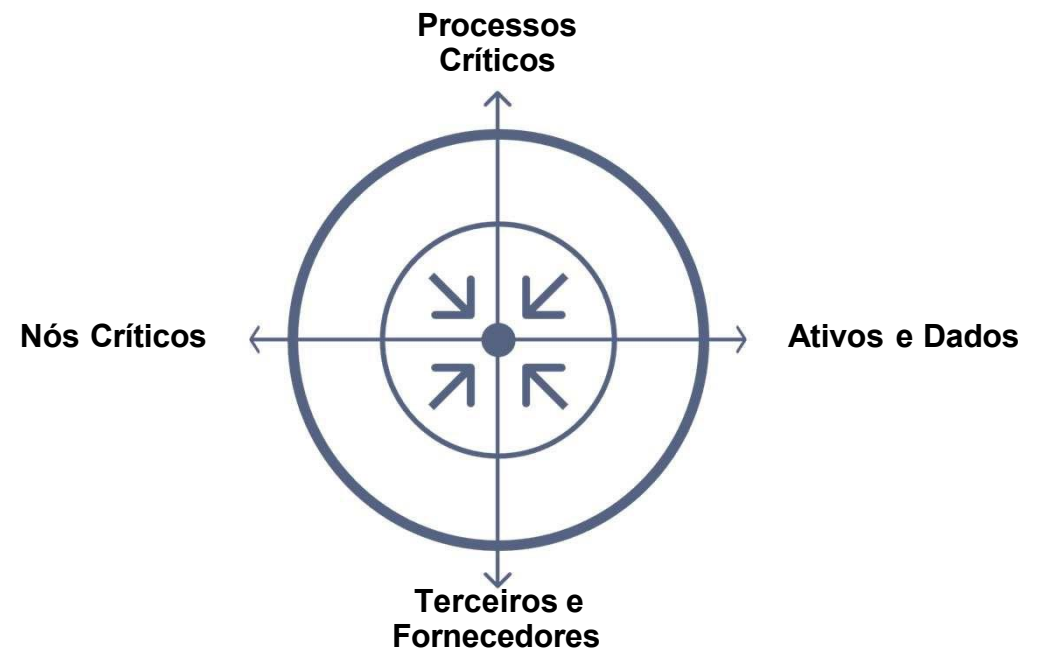
Quiz

Mapeamento da Cadeia de Valor e Dependências Críticas

O primeiro trabalho do CISO

Mapear cadeia de valor, processos críticos, dados, aplicações, identidades, infraestruturas e terceiros para perceber onde uma falha gera paragem, perda de confiança ou incumprimento.

- Mapear ponta a ponta, e não por silos tecnológicos
- Relacionar processo, ativo, fornecedor e requisito de resiliência
- Identificar dependências invisíveis, concentrações e single points of failure



Estudo de caso (1/4)



Decisão estratégica na AlfaMarket

A AlfaMarket é uma empresa de retalho omnicanal com 120 lojas físicas, canal de e-commerce em crescimento, ERP central, operadores logísticos externos, CRM, fornecedor cloud, plataforma de pagamentos e um novo piloto de IA para personalização de campanhas. Tem ainda um SI de Payroll com funções base.

O CEO quer acelerar o crescimento digital, reduzir ruturas operacionais e melhorar a experiência do cliente, mas o board está preocupado com dependências de terceiros, interrupções operacionais e exposição de dados.

Nos últimos 12 meses, a empresa registou três sinais de alerta: indisponibilidade temporária do operador logístico, falhas de sincronização entre e-commerce e ERP e atraso na avaliação do risco de um novo fornecedor de analytics.

Estudo de caso (2/4)



Decisão estratégica na AlfaMarket

Posicione os SI da AlfaMarket e Justifique

Item	Quadrante (Suporte, Operacional, Estratégico, Potencial)	Justificação
Payroll e colaboração interna	Suporte	Sem impacto direto nas operações, nem no Cliente, ou na diferenciação competitiva
ERP central	Operacional	Impacto direto nas operações e risco de negócio (operacional, reputacional, financeiro)
Operador logístico	Operacional*	Impacto direto nas operações* (se entregas diferenciadas)
Piloto de IA para campanhas	Exploratório	Inovação que está a ser acompanhada
Plataforma e-commerce	Estratégico	Está alinhada com a diferenciação da empresa
Dados de cliente e CRM	Estratégico	<i>idem</i>
Prestador cloud	Operacional	Infraestrutura dos SI operacionais

Estudo de caso (3/4)



Quais as dependências (tecnológicas) críticas na AlfaMarket?

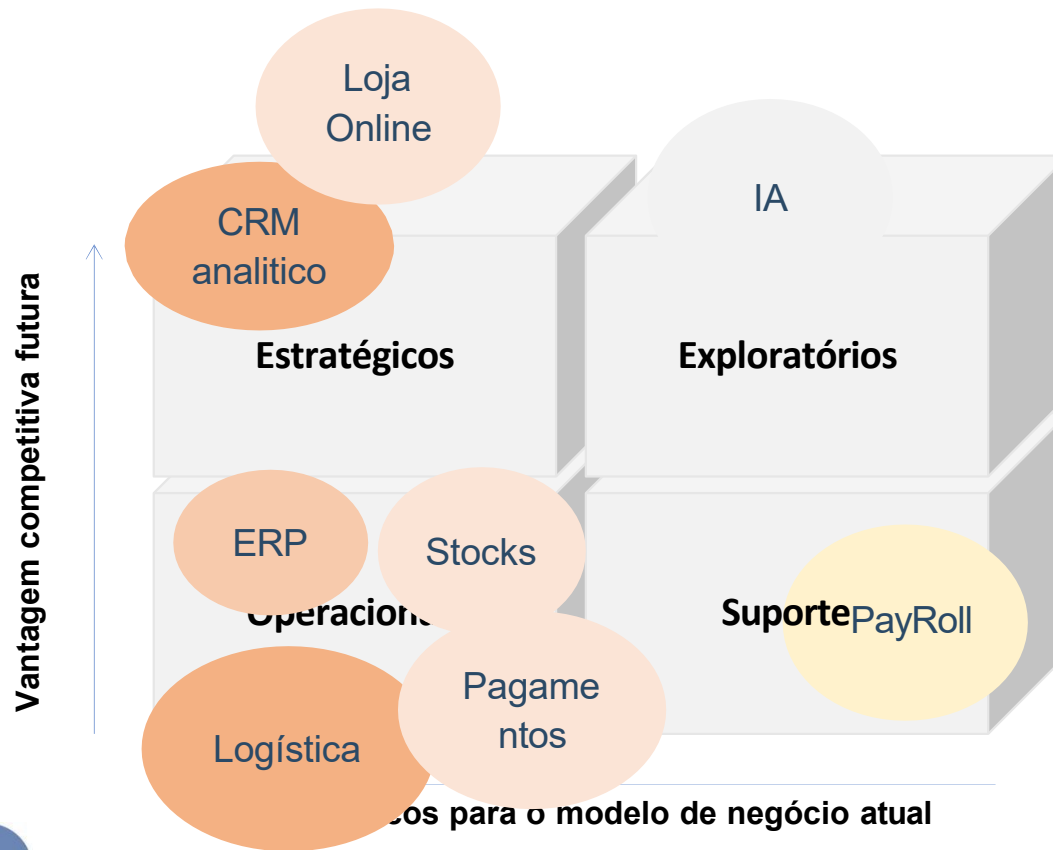
Posicione os SI da AlfaMarket e Justifique

Processo	Sistemas / Infraestruturas / Entidades	Grau de criticidade / Entidades (1 Baixo 2 Médio 3 Alto 4 Crítico)
eCommerce	• ERP/Gestão de stocks • CRM, gestão de clientes • Pagamentos • Logística • Cloud (infraestrutura)	Crítico Crítico Crítico – Payment service Provider Crítico – Operador externo Crítico – Cloud service Provider
Gestão de stock e reposição	• Lojas físicas • eCommerce • Logística • (Cloud)	Crítico Alto Crítico – Operador externo Crítico – Cloud service
Pagamentos	• Lojas físicas • eCommerce	Crítico Alto
Logística/entrega	• Lojas físicas • eCommerce • ERP	Crítico - Operador externo Alto - Operador externo Crítico
ERP		Crítico
Análise de Cliente	• CRM	Alto – Fornecedor de análise de dados

Modelo de decisão estratégica

Como funciona?

Dê exemplos de tipos de SI e posicione-os na Matriz de MacFarlan



#	SI	Portfolio
1		
2		
3		
4		
5		
6		
7		
8		
9		
10		

1

2

3

4

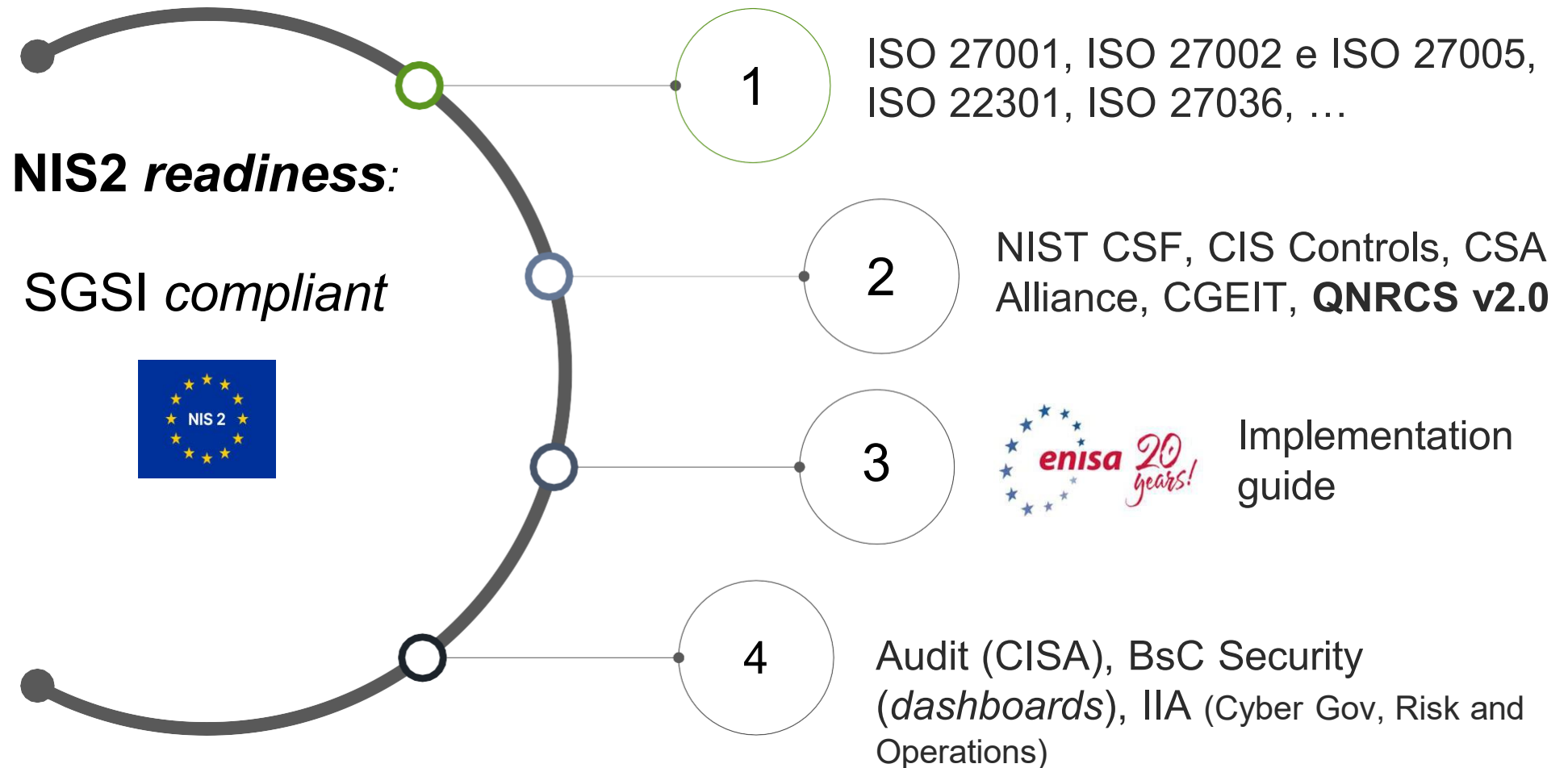
Estudo de caso



O Sistema de Gestão de Segurança de Informação

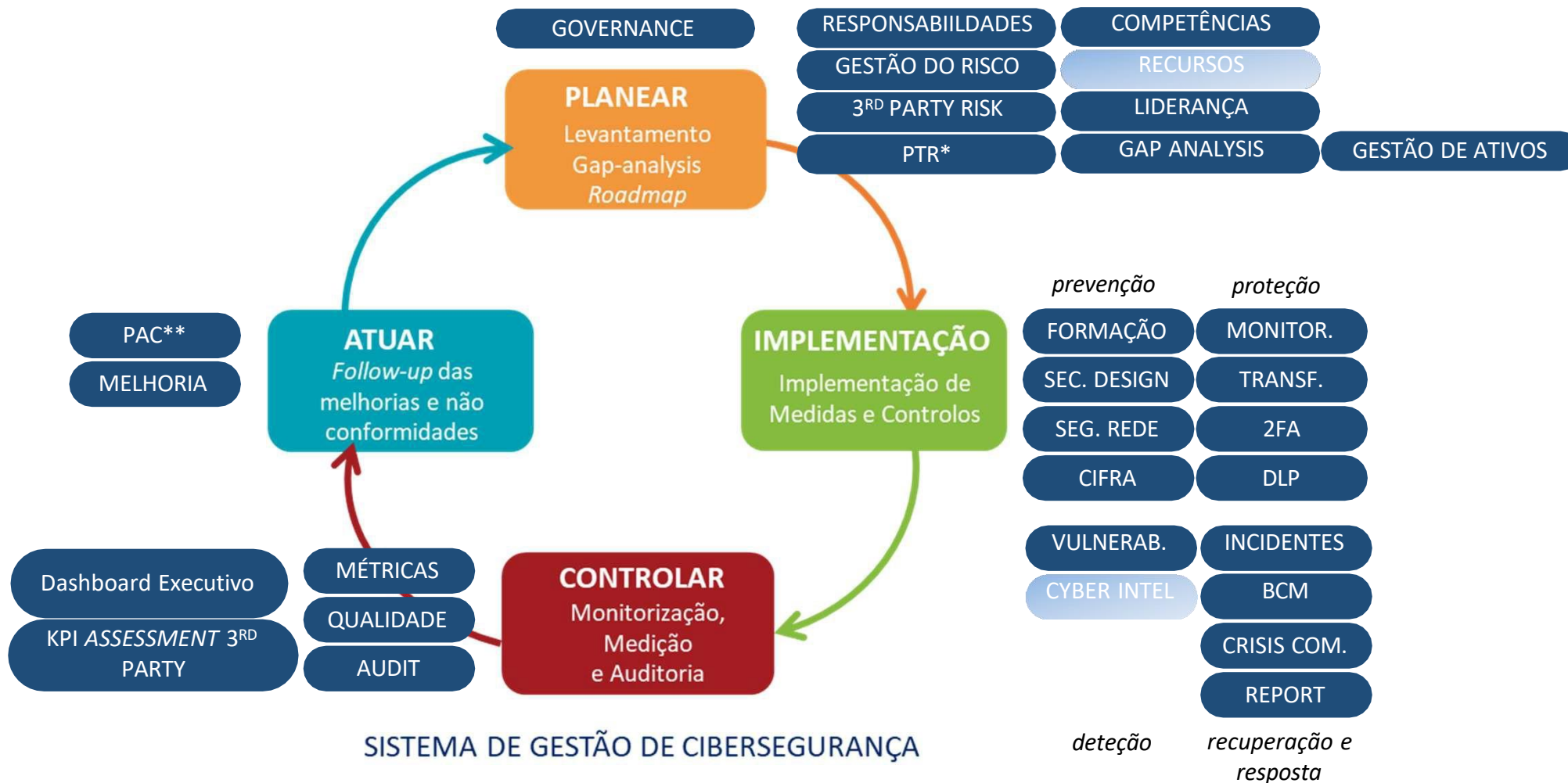
- Governance vs. Gestão
- SGSI
- Papel dos Referenciais

Framework de trabalho



Fonte: Bruno Marques

NIS2: como gerir cibersegurança?



* PTR – plano de tratamento dos riscos | PAC – plano de ações corretivas

O SGSI como Sistema Nervoso do Negócio



O Sistema de Gestão de Segurança da Informação (SGSI), definido pela **ISO/IEC 27001**, é o framework que permite operacionalizar a segurança no contexto do negócio. **Funciona como o sistema nervoso da organização — coordenando governação, risco e controlo de forma integrada e contínua.**

Modelo de Governo

Define papéis, responsabilidades e políticas que garantem que a segurança é gerida ao nível executivo com accountability clara.

Alinhamento e Gestão do Risco

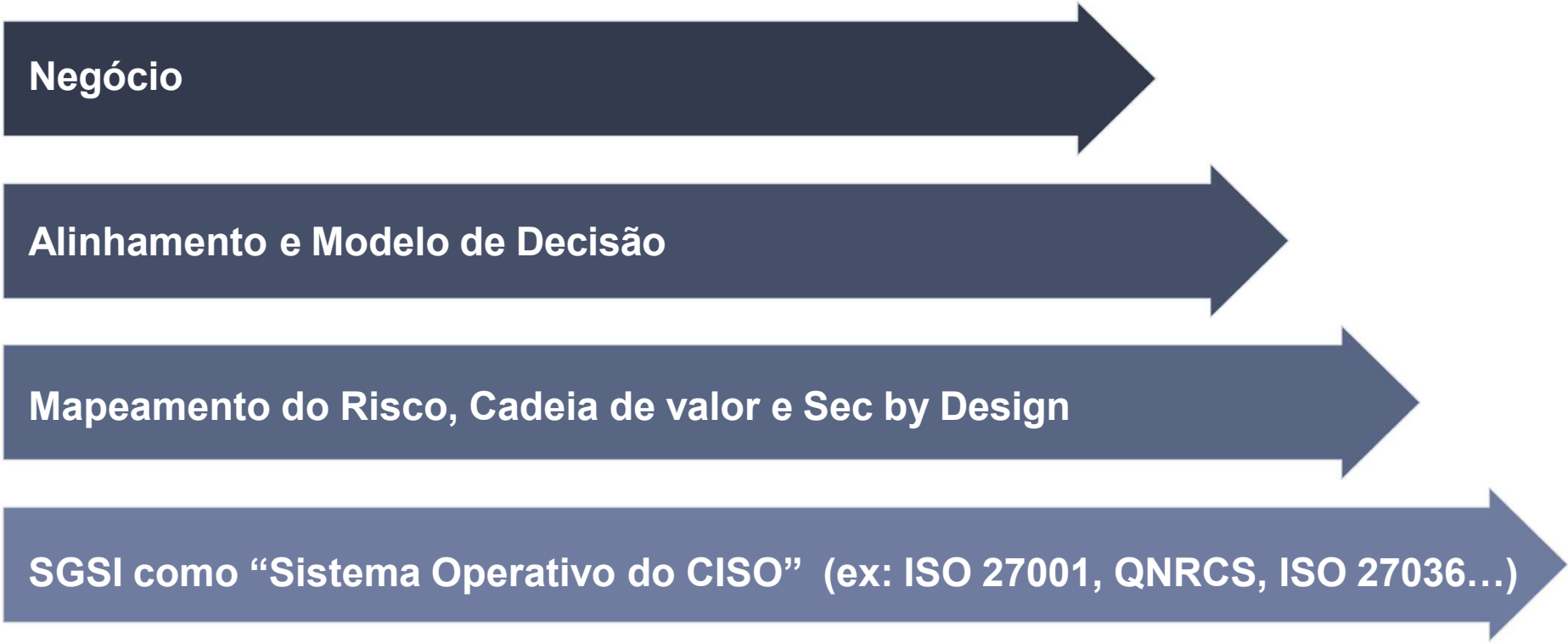
Estabelece um processo sistemático de identificação, avaliação e tratamento de riscos baseado no contexto e nos objetivos do negócio.

Ciclo de Planeamento e Controlo Contínuo

Implementa controlos de segurança proporcionais ao risco e garante a sua eficácia através de monitorização, auditoria e melhoria contínua.

Modelo Integrado — Tudo Converge no SGSI

Os conceitos abordados estão interligados num modelo coerente onde o SGSI funciona como o elemento integrador que transforma estratégia em resiliência operacional.



Negócio

Alinhamento e Modelo de Decisão

Mapeamento do Risco, Cadeia de valor e Sec by Design

SGSI como “Sistema Operativo do CISO” (ex: ISO 27001, QNRCS, ISO 27036...)

Anexo - Frameworks de Referência

O ecossistema regulatório e normativo fornece ao CISO os alicerces para uma gestão de risco estruturada e reconhecida internacionalmente.



NIS2

Diretiva europeia que impõe obrigações de gestão de risco e reporte de incidentes, incluindo a cadeia de fornecimento



ENISA

Orientações técnicas e boas práticas para a gestão de risco em cibersegurança ao nível europeu



ISO 27036

Norma internacional dedicada à segurança da informação nas relações com fornecedores e terceiros



ISACA

Framework de gestão integrada de fornecedores, cobrindo performance, risco e governance contínua

Como deve o CISO comunicar com o *board*?

- a) Linguagem detalhada e exaustiva, com base em indicadores operacionais
- b) Através de relatórios das ferramentas utilizadas, com foco no número de eventos e operações internas
- c) Com base em fatores críticos para o negócio com linguagem do risco, impacto e valor, bem como com indicadores executivos
- d) Através de relatórios periódicos, pelo menos de 6 em 6 meses, garantindo que o board tem informação

Quiz

Conclusão

Conclusões

1 **Cibersegurança = Componente Core do Negócio**

Não é suporte técnico. É uma função estratégica que habilita a operação, protege a reputação e gera confiança no mercado.

2 **Modelo de Decisão Estratégica = Foco do CISO em 4 Vetores**

Matriz de MacFarlan, Cadeia de Valor, Sec by Design e TPRM (Gestão de 3rd Party)

3 **CISO = Líder Estratégico, Não Técnico**

O CISO moderno é um gestor de risco, um comunicador executivo e um parceiro de negócio — que também domina a tecnologia.

4 **SGSI = Framework que Liga Tudo**

Estrutura operacional que transforma políticas em controles, controles em resiliência e resiliência em confiança.

5 **Segurança Integrada em Todo o Ciclo de Vida**

Do planejamento à descontinuação — a segurança deve estar presente em cada fase, como exige a NIS2 e as boas práticas

A cibersegurança não é tecnologia – é decisão de gestão

Cibersegurança não é IT

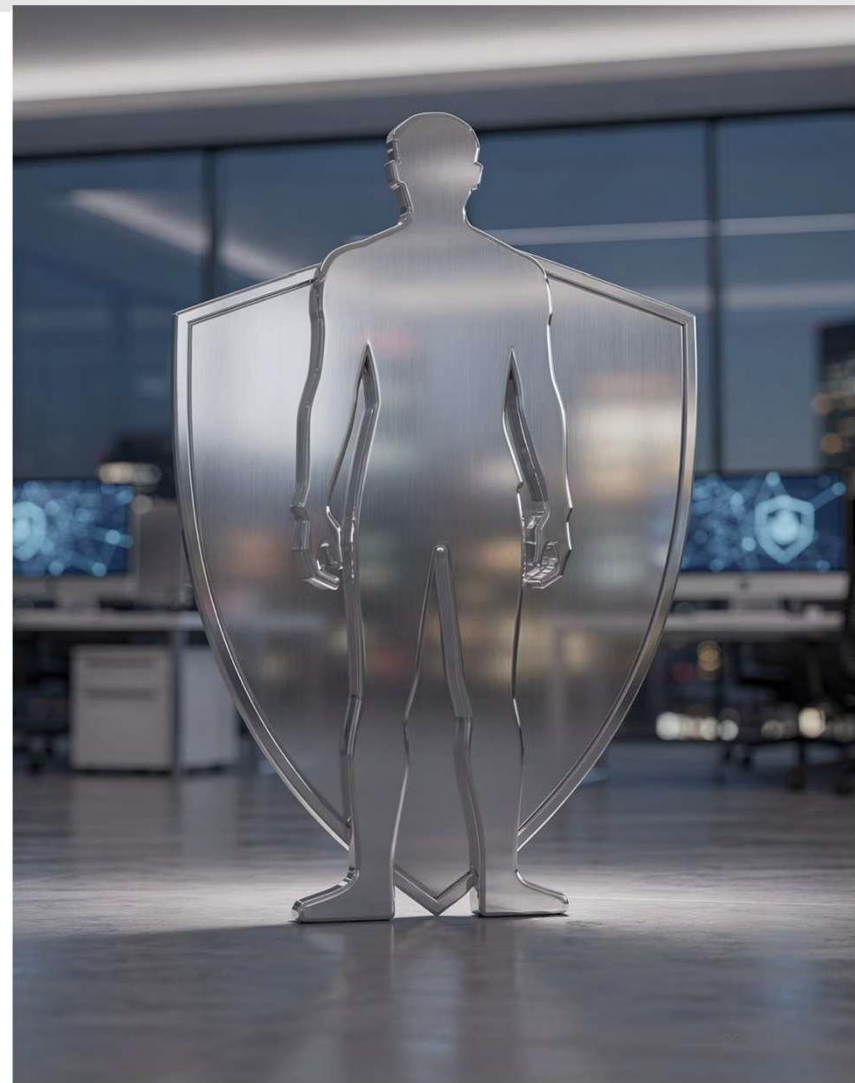
A proteção não começa no IT — começa na priorização do risco e do impacto no negócio

Decisão e Dados = poder

Investir onde o impacto é maior (McFarlan); aceitar o risco onde não é crítico

Investimento real

Cibersegurança não começa na conformidade — começa nas decisões com base no risco, ancoradas na NIS2 e em boas práticas



Questões?

Obrigado!